AURELIUS DIGITAL SYSTEMS PVT. LTD.

DATA PRIVACY & DATA GOVERNANCE POLICY

PRIV-DG-02 | Version 4.3

Field	Controlled value
Document ID	PRIV-DG-02
Version	4.3
Effective date	2026-08-01
Review date	2027-07-31
Classification	INTERNAL
Owner	Priyanka Sethi (DPO)
Approver	Arjun Malhotra (General Counsel), with DPO concurrence
Department	Data Protection Office / Legal & Corporate Affairs
Applicability	All workers and processing of Personal Data or governed enterprise/client data
Status	APPROVED - CONTROLLED INTERNAL DOCUMENT

Fictional enterprise notice: Aurelius Digital Systems Pvt. Ltd., its identities, systems and internal rules in this document are fictional.

Document Control

PRIV-DG-02-DC01 - Document-Control Record

Field	Controlled value
Document ID	PRIV-DG-02
Title	Data Privacy & Data Governance Policy
Version	4.3
Status	Approved - Controlled Internal Document
Effective date	2026-08-01
Review date	2027-07-31
Owner	Priyanka Sethi (DPO)
Approver	Arjun Malhotra (General Counsel), with DPO concurrence
Department	Data Protection Office / Legal & Corporate Affairs
Classification	INTERNAL
Applicability	All workers and processing of Personal Data or governed enterprise/client data
Controlled repository	VaultPoint DMS
Distribution	Authorized workforce and functions according to classification and applicability
External-law treatment	Where a decision depends on external law or a client obligation not contained here, obtain verified guidance from Legal & Corporate Affairs.

Revision History

PRIV-DG-02-RH01 - Revision History

Version	Effective / status	Meaningful change
2.3	Prior controlled release	Initial controlled issue and consolidation of predecessor guidance.
2.8	Prior controlled release	Expanded scope, roles and source-of-truth controls.
3.3	Prior controlled release	Aligned enterprise systems, approval vocabulary and document interfaces.
3.7	Prior controlled release	Added clearer exception, recordkeeping and manager/accountability rules.
4.0	Prior controlled release	Refreshed operational workflows, conditional rules and cross-document handoffs.
4.3	2026-08-01	Current release aligned to enterprise governance baseline and approved process design.

Precedence: This document controls only within its approved subject. Specialist policies, standards and procedures control detailed requirements in their own subject matter; unresolved conflicts are escalated to the relevant Policy Owners.

Table of Contents

1 Purpose, Scope and Privacy Governance Status
- 1.1 Purpose
- 1.2 Applicability
- 1.3 No statutory-claim rule
- 1.4 Relationship to security and contractual requirements

2 Privacy and Data Governance Roles
- 2.1 DPO and Data Protection Office
- 2.2 Data Owners
- 2.3 System and Business Owners
- 2.4 Processors and operational teams
- 2.5 Governance forums and escalation

3 Data Types, Classification and Risk Labels
- 3.1 Personal Data
- 3.2 High-Sensitivity Personal Data
- 3.3 Client Data and Company Data
- 3.4 Information classification overlay
- 3.5 Combined datasets

4 Internal Privacy Principles and Permitted Use
- 4.1 Purpose alignment
- 4.2 Minimum necessary use
- 4.3 Access limitation
- 4.4 Accuracy and quality
- 4.5 Retention discipline
- 4.6 Accountability

5 Collection, Notices and Transparency
- 5.1 Collection design
- 5.2 Notice ownership
- 5.3 Indirect collection
- 5.4 Change of purpose
- 5.5 Recording collection context

6 Employee and Workforce Data
- 6.1 HR data
- 6.2 Recruitment and onboarding data
- 6.3 Performance and learning data
- 6.4 Security/attendance records
- 6.5 Restricted access to workforce data

7 Client, Customer and Delivery Data
- 7.1 Client Data handling
- 7.2 Client instructions and contractual constraints
- 7.3 Support and telemetry data
- 7.4 Data segregation
- 7.5 Delivery-team access

8 Access, Internal Sharing and Disclosure
- 8.1 Need-to-know
- 8.2 Internal sharing
- 8.3 External disclosure
- 8.4 Bulk exports
- 8.5 Recipient verification
- 8.6 Data Owner approval

9 Third Parties and International Transfers
- 9.1 Third-party processing
- 9.2 Vendor due diligence handoff
- 9.3 Contractual/privacy review
- 9.4 Cross-border transfer review
- 9.5 Subprocessors
- 9.6 Termination and data return/deletion

10 Retention, Archiving and Deletion
- 10.1 Retention schedules

10.2 Operational versus record copies
10.3 Legal/contract holds as external constraints
10.4 Deletion requests

Table of Contents - continued

10.5 Secure deletion evidence
10.6 Backups and residual copies
11 Individual Requests and Privacy Case Handling
11.1 Request intake
11.2 Identity/authority verification
11.3 Search and response coordination
11.4 Correction and deletion requests
11.5 Escalation
11.6 PrivacyCase records
12 Employee Monitoring, Logs and Telemetry
12.1 Business/security purpose
12.2 Proportionality and access controls
12.3 Monitoring notices
12.4 Use of security telemetry
12.5 Manager access boundaries
13 Privacy by Design and Change Review
13.1 Trigger criteria
13.2 Design review
13.3 Data-flow mapping
13.4 Risk assessment
13.5 Approval and remediation
13.6 Change re-review
14 AI/ML, Analytics and Model Data Use
14.1 Training datasets
14.2 Fine-tuning and model inputs
14.3 Prompts and retrieved context
14.4 Embeddings and vector stores
14.5 Logs and evaluation datasets
14.6 Synthetic/anonymized data
14.7 AI governance handoff
15 Anonymization and Pseudonymization
15.1 Purpose and limits
15.2 Pseudonymous identifiers
15.3 Re-identification controls
15.4 Release review
15.5 Documentation
16 Privacy Incidents and Security Coordination
16.1 Privacy Incident definition
16.2 Immediate reporting
16.3 Security Incident overlap
16.4 DPO involvement
16.5 Containment and assessment
16.6 External notification decisions as separately verified/legal-led
17 Records, Governance Evidence and Accountability
17.1 Processing records
17.2 PrivacyCase records
17.3 Data Owner decisions
17.4 Exception records
17.5 Audit support
18 Exceptions and Escalation
18.1 Exception criteria
18.2 Specialist concurrence
18.3 Time-bounded approval
18.4 EREC escalation
18.5 Review and expiry
19 Training, Assurance and Review
19.1 Privacy learning
19.2 Control monitoring

19.3 Internal assurance
19.4 Policy review
19.5 Metrics

Document Governance and Use

Define Aurelius internal privacy and data-governance requirements for Personal Data and governed enterprise/client data without asserting jurisdiction-specific statutory obligations.

Collection, use, access, sharing, retention, deletion, anonymization, pseudonymization, third parties, transfers, employee monitoring, privacy by design, AI/ML data use, requests, incidents, governance and records.

Audience: All workers; Data Owners; system owners; Legal; Data Protection Office; Security; AI/Data teams; HR; vendor managers; client delivery teams.

Controlled-source rule: Convenience copies, email extracts, screenshots and local notes do not supersede the controlled document or authoritative enterprise system for the relevant fact.

PRIV-DG-02-DG01 - Document Dependencies

Dependency type	Documents
Primary	
Control	

1 Purpose, Scope and Privacy Governance Status

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 1 Purpose, Scope and Privacy Governance Status | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Purpose, Scope and Privacy Governance Status establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

1.1 Purpose

Purpose is governed as part of Purpose, Scope and Privacy Governance Status. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For purpose, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

1.2 Applicability

Applicability is governed as part of Purpose, Scope and Privacy Governance Status. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For applicability, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

1.3 No statutory-claim rule

No statutory-claim rule is governed as part of Purpose, Scope and Privacy Governance Status. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For statutory, claim, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

1.4 Relationship to security and contractual requirements

Relationship to security and contractual requirements is governed as part of Purpose, Scope and Privacy Governance Status. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For relationship, security, contractual, requirements, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

2 Privacy and Data Governance Roles

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 2 Privacy and Data Governance Roles | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Privacy and Data Governance Roles establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

2.1 DPO and Data Protection Office

DPO and Data Protection Office is governed as part of Privacy and Data Governance Roles. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For protection, office, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

PRIV-DG-02-T01 - Privacy/Data Governance Role Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

2 Privacy and Data Governance Roles - continued

2.2 Data Owners

Data Owners is governed as part of Privacy and Data Governance Roles. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For owners, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Operational scenario S01: Employee exports PeopleHub employee data into a spreadsheet for an unofficial analysis. Apply the requirements in Data Privacy & Data Governance Policy to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

2.3 System and Business Owners

System and Business Owners is governed as part of Privacy and Data Governance Roles. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For system, business, owners, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

2.4 Processors and operational teams

Processors and operational teams is governed as part of Privacy and Data Governance Roles. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For processors, operational, teams, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

2.5 Governance forums and escalation

Governance forums and escalation is governed as part of Privacy and Data Governance Roles. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For governance, forums, escalation, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

3 Data Types, Classification and Risk Labels

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 3 Data Types, Classification and Risk Labels | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Data Types, Classification and Risk Labels establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

3.1 Personal Data

Personal Data is governed as part of Data Types, Classification and Risk Labels. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For personal, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

PRIV-DG-02-T02 - Data Type and Classification Overlay

Code	Class	Definition	Minimum handling
ADS-PUB	PUBLIC	Information approved for unrestricted external distribution by an authorized owner or publication process.	Integrity and authorized-publication controls; no assumption that all externally visible drafts are Public.
ADS-INT	INTERNAL	Default company information intended for Aurelius workforce use and not approved for public release.	Use company-approved systems; share externally only for legitimate business need and with appropriate authorization.
ADS-CONF	CONFIDENTIAL	Information whose unauthorized disclosure, alteration, or loss could materially harm Aurelius, a client, worker, or business relationship.	Need-to-know access; approved managed systems; encryption in transit and at rest where supported; controlled external sharing; enhanced logging where applicable.
ADS-REST	RESTRICTED	Highest internal protection level for information requiring tightly limited access because compromise could cause severe harm or enable material misuse.	Explicit authorized users; strongest available access controls; managed storage only; no public AI submission; no unmanaged removable media; specialist approval for external transfer.

3.2 High-Sensitivity Personal Data

High-Sensitivity Personal Data is governed as part of Data Types, Classification and Risk Labels. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For sensitivity, personal, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

3.3 Client Data and Company Data

Client Data and Company Data is governed as part of Data Types, Classification and Risk Labels. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For client, company, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Operational scenario S02: Support engineer sees client contact data outside assigned accounts. Apply the requirements in Data Privacy & Data Governance Policy to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

3.4 Information classification overlay

Information classification overlay is governed as part of Data Types, Classification and Risk Labels. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For information, classification, overlay, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Related controlled source: Information Security Policy & Procedures Manual (SEC-POL-01) §3 - Security classification handling. This reference supplements this section and does not transfer ownership of unrelated rules.

3.5 Combined datasets

Combined datasets is governed as part of Data Types, Classification and Risk Labels. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For combined, datasets, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

4 Internal Privacy Principles and Permitted Use

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 4 Internal Privacy Principles and Permitted Use | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Internal Privacy Principles and Permitted Use establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

4.1 Purpose alignment

Purpose alignment is governed as part of Internal Privacy Principles and Permitted Use. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For purpose, alignment, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

4.2 Minimum necessary use

Minimum necessary use is governed as part of Internal Privacy Principles and Permitted Use. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For minimum, necessary, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

PRIV-DG-02-T03 - Permitted-Use Review Questions

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

4.3 Access limitation

Access limitation is governed as part of Internal Privacy Principles and Permitted Use. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For access, limitation, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

4.4 Accuracy and quality

Accuracy and quality is governed as part of Internal Privacy Principles and Permitted Use. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For accuracy, quality, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

4.5 Retention discipline

Aurelius retention periods are internal governance baselines and may be overridden by a verified external or client-specific obligation. Unless a more specific approved schedule applies, recruitment candidate records are retained for 24 months after the last recruitment activity; core employee master records for 7 years after separation; routine security telemetry for 180 days; and delivery records according to the approved client/project record schedule.

Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For retention, discipline, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Operational scenario S03: Project wants to reuse client data to train an internal model. Stop further submission, preserve the relevant details, notify the Security Operations Centre and Privacy where personal/client data may be involved, and follow AI-GOV-05 for use-case/tool review. Do not attempt to erase evidence by altering logs or accounts.

4.6 Accountability

Accountability is governed as part of Internal Privacy Principles and Permitted Use. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For accountability, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

5 Collection, Notices and Transparency

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 5 Collection, Notices and Transparency | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Collection, Notices and Transparency establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

5.1 Collection design

Collection design is governed as part of Collection, Notices and Transparency. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For collection, design, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

5.2 Notice ownership

Notice ownership is governed as part of Collection, Notices and Transparency. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For notice, ownership, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

5.3 Indirect collection

Indirect collection is governed as part of Collection, Notices and Transparency. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For indirect, collection, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

5.4 Change of purpose

Change of purpose is governed as part of Collection, Notices and Transparency. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For change, purpose, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

5.5 Recording collection context

Recording collection context is governed as part of Collection, Notices and Transparency. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For recording, collection, context, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Operational scenario S04: Team proposes storing embeddings of CONFIDENTIAL source material in VectorCore. Apply the requirements in Data Privacy & Data Governance Policy to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

6 Employee and Workforce Data

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 6 Employee and Workforce Data | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Employee and Workforce Data establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

6.1 HR data

HR data is governed as part of Employee and Workforce Data. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For this activity, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

6.2 Recruitment and onboarding data

Recruitment and onboarding data is governed as part of Employee and Workforce Data. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For recruitment, onboarding, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

6.3 Performance and learning data

Performance and learning data is governed as part of Employee and Workforce Data. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For performance, learning, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

6.4 Security/attendance records

Security/attendance records is governed as part of Employee and Workforce Data. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For security, attendance, records, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

6.5 Restricted access to workforce data

Restricted access to workforce data is governed as part of Employee and Workforce Data. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For restricted, access, workforce, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Related controlled source: Code of Conduct & Business Ethics (ETH-COC-01) §6 - Confidentiality duty. This reference supplements this section and does not transfer ownership of unrelated rules.

7 Client, Customer and Delivery Data

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 7 Client, Customer and Delivery Data | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Client, Customer and Delivery Data establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

7.1 Client Data handling

Client Data handling is governed as part of Client, Customer and Delivery Data. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For client, handling, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Operational scenario S05: Employee accidentally emails personal data to the wrong internal distribution list. Stop further submission, preserve the relevant details, notify the Security Operations Centre and Privacy where personal/client data may be involved, and follow AI-GOV-05 for use-case/tool review. Do not attempt to erase evidence by altering logs or accounts.

7.2 Client instructions and contractual constraints

Client instructions and contractual constraints is governed as part of Client, Customer and Delivery Data. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For client, instructions, contractual, constraints, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

7.3 Support and telemetry data

Workforce monitoring must have a defined business or security purpose, use the minimum data reasonably required and be limited to authorized reviewers. Monitoring data is not a general-purpose management resource. New or materially expanded monitoring requires Privacy and Security review before deployment.

Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For support, telemetry, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

7.4 Data segregation

Data segregation is governed as part of Client, Customer and Delivery Data. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For segregation, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

7.5 Delivery-team access

Delivery-team access is governed as part of Client, Customer and Delivery Data. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For delivery, access, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

8 Access, Internal Sharing and Disclosure

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 8 Access, Internal Sharing and Disclosure | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Access, Internal Sharing and Disclosure establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

8.1 Need-to-know

Need-to-know is governed as part of Access, Internal Sharing and Disclosure. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For this activity, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Related controlled source: Identity, Access Management & Acceptable Technology Use Standard (IAM-STD-03) §6 - Least privilege/access design. This reference supplements this section and does not transfer ownership of unrelated rules.

8.2 Internal sharing

Internal sharing is governed as part of Access, Internal Sharing and Disclosure. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For internal, sharing, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

PRIV-DG-02-T04 - Internal/External Sharing Decision Matrix

Situation	Primary approver	Specialist concurrence	Evidence
Routine request	Line Manager / designated owner	As triggered	Business purpose + workflow record
Material or high-risk request	Functional Head / Business Owner	Security/Privacy/Legal/Finance as applicable	Risk and exception rationale
Enterprise exception	Executive Approver or governance committee	Policy Owner	Scope, conditions, expiry, review date

8.3 External disclosure

External disclosure is governed as part of Access, Internal Sharing and Disclosure. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For external, disclosure, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Operational scenario S06: Vendor wants a copy of employee contact data for service delivery. Apply the requirements in Data Privacy & Data Governance Policy to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

8.4 Bulk exports

Bulk exports is governed as part of Access, Internal Sharing and Disclosure. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For exports, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

8.5 Recipient verification

Recipient verification is governed as part of Access, Internal Sharing and Disclosure. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For recipient, verification, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

8.6 Data Owner approval

Data Owner approval is governed as part of Access, Internal Sharing and Disclosure. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For owner, approval, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

9 Third Parties and International Transfers

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 9 Third Parties and International Transfers | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Third Parties and International Transfers establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

9.1 Third-party processing

Third-party processing is governed as part of Third Parties and International Transfers. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For third, party, processing, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

PRIV-DG-02-T05 - Third-Party Privacy Review Triggers

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

9.2 Vendor due diligence handoff

Vendor due diligence handoff is governed as part of Third Parties and International Transfers. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For vendor, diligence, handoff, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Related controlled source: Procurement, Vendor & Third-Party Risk Management Policy (PROC-TPRM-11) §9 - Third-party privacy/security review. This reference supplements this section and does not transfer ownership of unrelated rules.

9.3 Contractual/privacy review

Contractual/privacy review is governed as part of Third Parties and International Transfers. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For contractual, privacy, review, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Operational scenario S07: Manager asks Security for raw monitoring logs about an employee without a defined need. Apply the requirements in Data Privacy & Data Governance Policy to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

9.4 Cross-border transfer review

Cross-border transfer review is governed as part of Third Parties and International Transfers. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For cross, border, transfer, review, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

9.5 Subprocessors

Subprocessors is governed as part of Third Parties and International Transfers. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For subprocessors, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

9.6 Termination and data return/deletion

Aurelius retention periods are internal governance baselines and may be overridden by a verified external or client-specific obligation. Unless a more specific approved schedule applies, recruitment candidate records are retained for 24 months after the last recruitment activity; core employee master records for 7 years after separation; routine security telemetry for 180 days; and delivery records according to the approved client/project record schedule.

Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For termination, return, deletion, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

10 Retention, Archiving and Deletion

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 10 Retention, Archiving and Deletion | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Retention, Archiving and Deletion establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

10.1 Retention schedules

Aurelius retention periods are internal governance baselines and may be overridden by a verified external or client-specific obligation. Unless a more specific approved schedule applies, recruitment candidate records are retained for 24 months after the last recruitment activity; core employee master records for 7 years after separation; routine security telemetry for 180 days; and delivery records according to the approved client/project record schedule.

Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For retention, schedules, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

PRIV-DG-02-T06 - Retention/Deletion Decision Matrix

Situation	Primary approver	Specialist concurrence	Evidence
Routine request	Line Manager / designated owner	As triggered	Business purpose + workflow record
Material or high-risk request	Functional Head / Business Owner	Security/Privacy/Legal/Finance as applicable	Risk and exception rationale
Enterprise exception	Executive Approver or governance committee	Policy Owner	Scope, conditions, expiry, review date

10.2 Operational versus record copies

Operational versus record copies is governed as part of Retention, Archiving and Deletion. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For operational, versus, record, copies, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

10.3 Legal/contract holds as external constraints

Legal/contract holds as external constraints is governed as part of Retention, Archiving and Deletion. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For legal, contract, holds, external, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Operational scenario S08: Data Owner wants to downgrade a dataset after removing direct identifiers. Apply the requirements in Data Privacy & Data Governance Policy to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

10.4 Deletion requests

Aurelius retention periods are internal governance baselines and may be overridden by a verified external or client-specific obligation. Unless a more specific approved schedule applies, recruitment candidate records are retained for 24 months after the last recruitment activity; core employee master records for 7 years after separation; routine security telemetry for 180 days; and delivery records according to the approved client/project record schedule.

Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For deletion, requests, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

10.5 Secure deletion evidence

Aurelius retention periods are internal governance baselines and may be overridden by a verified external or client-specific obligation. Unless a more specific approved schedule applies, recruitment candidate records are retained for 24 months after the last recruitment activity; core employee master records for 7 years after separation; routine security telemetry for 180 days; and delivery records according to the approved client/project record schedule.

Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For secure, deletion, evidence, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

10.6 Backups and residual copies

Backups and residual copies is governed as part of Retention, Archiving and Deletion. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For backups, residual, copies, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

11 Individual Requests and Privacy Case Handling

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 11 Individual Requests and Privacy Case Handling | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Individual Requests and Privacy Case Handling establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

11.1 Request intake

Request intake is governed as part of Individual Requests and Privacy Case Handling. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For request, intake, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

11.2 Identity/authority verification

Identity/authority verification is governed as part of Individual Requests and Privacy Case Handling. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For identity, authority, verification, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

PRIV-DG-02-T07 - Privacy Request Workflow and Owners

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

11.3 Search and response coordination

Search and response coordination is governed as part of Individual Requests and Privacy Case Handling. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For search, response, coordination, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

11.4 Correction and deletion requests

Aurelius retention periods are internal governance baselines and may be overridden by a verified external or client-specific obligation. Unless a more specific approved schedule applies, recruitment candidate records are retained for 24 months after the last recruitment activity; core employee master records for 7 years after separation; routine security telemetry for 180 days; and delivery records according to the approved client/project record schedule.

Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For correction, deletion, requests, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Operational scenario S09: Deletion request conflicts with an active record-preservation instruction. Apply the requirements in Data Privacy & Data Governance Policy to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

11.5 Escalation

Escalation is governed as part of Individual Requests and Privacy Case Handling. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For escalation, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

11.6 PrivacyCase records

PrivacyCase records is governed as part of Individual Requests and Privacy Case Handling. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For privacycase, records, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

12 Employee Monitoring, Logs and Telemetry

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 12 Employee Monitoring, Logs and Telemetry | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Employee Monitoring, Logs and Telemetry establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

12.1 Business/security purpose

Business/security purpose is governed as part of Employee Monitoring, Logs and Telemetry. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For business, security, purpose, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

12.2 Proportionality and access controls

Proportionality and access controls is governed as part of Employee Monitoring, Logs and Telemetry. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For proportionality, access, controls, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

12.3 Monitoring notices

Workforce monitoring must have a defined business or security purpose, use the minimum data reasonably required and be limited to authorized reviewers. Monitoring data is not a general-purpose management resource. New or materially expanded monitoring requires Privacy and Security review before deployment.

Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For monitoring, notices, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

12.4 Use of security telemetry

Workforce monitoring must have a defined business or security purpose, use the minimum data reasonably required and be limited to authorized reviewers. Monitoring data is not a general-purpose management resource. New or materially expanded monitoring requires Privacy and Security review before deployment.

Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For security, telemetry, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Operational scenario S10: Team wants to transfer a dataset to an overseas vendor region. Apply the requirements in Data Privacy & Data Governance Policy to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

12.5 Manager access boundaries

Manager access boundaries is governed as part of Employee Monitoring, Logs and Telemetry. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For manager, access, boundaries, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

13 Privacy by Design and Change Review

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 13 Privacy by Design and Change Review | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Privacy by Design and Change Review establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

13.1 Trigger criteria

Trigger criteria is governed as part of Privacy by Design and Change Review. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For trigger, criteria, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

13.2 Design review

Design review is governed as part of Privacy by Design and Change Review. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For design, review, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

PRIV-DG-02-T08 - Privacy-by-Design Review Triggers

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

13.3 Data-flow mapping

Data-flow mapping is governed as part of Privacy by Design and Change Review. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For mapping, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

13.4 Risk assessment

Risk assessment is governed as part of Privacy by Design and Change Review. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For assessment, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

13.5 Approval and remediation

Approval and remediation is governed as part of Privacy by Design and Change Review. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For approval, remediation, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

13.6 Change re-review

Change re-review is governed as part of Privacy by Design and Change Review. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For change, review, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Operational scenario S11: Public LLM prompt would contain customer information. Stop further submission, preserve the relevant details, notify the Security Operations Centre and Privacy where personal/client data may be involved, and follow AI-GOV-05 for use-case/tool review. Do not attempt to erase evidence by altering logs or accounts.

14 AI/ML, Analytics and Model Data Use

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 14 AI/ML, Analytics and Model Data Use | Data Protection Office / Legal & Corporate Affairs | INTERNAL

AI/ML, Analytics and Model Data Use establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

14.1 Training datasets

Training datasets is governed as part of AI/ML, Analytics and Model Data Use. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For training, datasets, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

PRIV-DG-02-T09 - AI/ML Data Governance Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

14.2 Fine-tuning and model inputs

Fine-tuning and model inputs is governed as part of AI/ML, Analytics and Model Data Use. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For tuning, model, inputs, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

14.3 Prompts and retrieved context

Prompts and retrieved context is governed as part of AI/ML, Analytics and Model Data Use. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For prompts, retrieved, context, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

14.4 Embeddings and vector stores

Embeddings and vector stores is governed as part of AI/ML, Analytics and Model Data Use. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For embeddings, vector, stores, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

14.5 Logs and evaluation datasets

Logs and evaluation datasets is governed as part of AI/ML, Analytics and Model Data Use. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For evaluation, datasets, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

14.6 Synthetic/anonymized data

Synthetic/anonymized data is governed as part of AI/ML, Analytics and Model Data Use. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For synthetic, anonymized, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Operational scenario S12: PrivacyCase receives a request but identity/authority is unclear. Apply the requirements in Data Privacy & Data Governance Policy to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

14.7 AI governance handoff

AI governance handoff is governed as part of AI/ML, Analytics and Model Data Use. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For governance, handoff, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Related controlled source: AI, Machine Learning & Generative AI Governance Standard (AI-GOV-05) §6 - AI data-classification/privacy gate. This reference supplements this section and does not transfer ownership of unrelated rules.

14 AI/ML, Analytics and Model Data Use - continued

15 Anonymization and Pseudonymization

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 15 Anonymization and Pseudonymization | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Anonymization and Pseudonymization establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

15.1 Purpose and limits

Purpose and limits is governed as part of Anonymization and Pseudonymization. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For purpose, limits, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

15.2 Pseudonymous identifiers

Pseudonymous identifiers is governed as part of Anonymization and Pseudonymization. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For pseudonymous, identifiers, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

15.3 Re-identification controls

Re-identification controls is governed as part of Anonymization and Pseudonymization. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For identification, controls, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

15.4 Release review

Release review is governed as part of Anonymization and Pseudonymization. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For release, review, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Operational scenario S13: AI evaluation dataset contains production support transcripts. Stop further submission, preserve the relevant details, notify the Security Operations Centre and Privacy where personal/client data may be involved, and follow AI-GOV-05 for use-case/tool review. Do not attempt to erase evidence by altering logs or accounts.

15.5 Documentation

Documentation is governed as part of Anonymization and Pseudonymization. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For documentation, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

16 Privacy Incidents and Security Coordination

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 16 Privacy Incidents and Security Coordination | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Privacy Incidents and Security Coordination establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

16.1 Privacy Incident definition

Privacy Incident definition is governed as part of Privacy Incidents and Security Coordination. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For privacy, incident, definition, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

16.2 Immediate reporting

Immediate reporting is governed as part of Privacy Incidents and Security Coordination. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For immediate, reporting, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

PRIV-DG-02-T10 - Privacy Incident Coordination Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

16.3 Security Incident overlap

Security Incident overlap is governed as part of Privacy Incidents and Security Coordination. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For security, incident, overlap, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Related controlled source: Security Incident Response & Business Continuity Manual (SEC-IR-004) §12 - Privacy/security incident coordination. This reference supplements this section and does not transfer ownership of unrelated rules.

16.4 DPO involvement

DPO involvement is governed as part of Privacy Incidents and Security Coordination. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For involvement, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

16.5 Containment and assessment

Containment and assessment is governed as part of Privacy Incidents and Security Coordination. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For containment, assessment, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

16.6 External notification decisions as separately verified/legal-led

External notification decisions as separately verified/legal-led is governed as part of Privacy Incidents and Security Coordination. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For external, notification, decisions, separately, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Operational scenario S14: Pseudonymized dataset can still be linked back using a separate key. Apply the requirements in Data Privacy & Data Governance Policy to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

17 Records, Governance Evidence and Accountability

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 17 Records, Governance Evidence and Accountability | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Records, Governance Evidence and Accountability establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

17.1 Processing records

Processing records is governed as part of Records, Governance Evidence and Accountability. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For processing, records, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

17.2 PrivacyCase records

PrivacyCase records is governed as part of Records, Governance Evidence and Accountability. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For privacycase, records, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

17.3 Data Owner decisions

Data Owner decisions is governed as part of Records, Governance Evidence and Accountability. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For owner, decisions, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

17.4 Exception records

Exception records is governed as part of Records, Governance Evidence and Accountability. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For exception, records, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

17.5 Audit support

Audit support is governed as part of Records, Governance Evidence and Accountability. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For audit, support, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

18 Exceptions and Escalation

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 18 Exceptions and Escalation | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Exceptions and Escalation establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

18.1 Exception criteria

Exception criteria is governed as part of Exceptions and Escalation. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For exception, criteria, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

18.2 Specialist concurrence

Specialist concurrence is governed as part of Exceptions and Escalation. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For specialist, concurrence, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

PRIV-DG-02-T11 - Privacy Exception Approval Matrix

Situation	Primary approver	Specialist concurrence	Evidence
Routine request	Line Manager / designated owner	As triggered	Business purpose + workflow record
Material or high-risk request	Functional Head / Business Owner	Security/Privacy/Legal/Finance as applicable	Risk and exception rationale
Enterprise exception	Executive Approver or governance committee	Policy Owner	Scope, conditions, expiry, review date

18.3 Time-bounded approval

Time-bounded approval is governed as part of Exceptions and Escalation. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For bounded, approval, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

18.4 EREC escalation

EREC escalation is governed as part of Exceptions and Escalation. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For escalation, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

18.5 Review and expiry

Review and expiry is governed as part of Exceptions and Escalation. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For review, expiry, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

19 Training, Assurance and Review

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section 19 Training, Assurance and Review | Data Protection Office / Legal & Corporate Affairs | INTERNAL

Training, Assurance and Review establishes the requirements, responsibilities and decision rules that apply within this part of Data Privacy & Data Governance Policy. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

19.1 Privacy learning

Privacy learning is governed as part of Training, Assurance and Review. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For privacy, learning, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

19.2 Control monitoring

Workforce monitoring must have a defined business or security purpose, use the minimum data reasonably required and be limited to authorized reviewers. Monitoring data is not a general-purpose management resource. New or materially expanded monitoring requires Privacy and Security review before deployment.

Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For control, monitoring, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

19.3 Internal assurance

Internal assurance is governed as part of Training, Assurance and Review. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For internal, assurance, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

19.4 Policy review

Policy review is governed as part of Training, Assurance and Review. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For policy, review, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

19.5 Metrics

Metrics is governed as part of Training, Assurance and Review. Personal and business data must be used for a defined, approved purpose and limited to people, systems and periods reasonably necessary for that purpose.

For metrics, teams must be able to explain the purpose, data categories, recipients, retention and control owner. The Data Protection Office may require a privacy review when a new use materially changes the people affected, data sensitivity, sharing, monitoring or automation.

- Collect and retain only data reasonably needed for the approved purpose.
- Limit internal sharing to roles with a business need and an authorized access path.
- Route new high-risk or ambiguous uses to privacy@aureliusdigital.example before implementation.

Appendices, Forms and Checklists

Data Privacy & Data Governance Policy | PRIV-DG-02 | v4.3 | Effective 2026-08-01 | Section Appendices Controlled execution aids | Data Protection Office / Legal & Corporate Affairs | INTERNAL

PRIV-DG-02-AA Privacy and Data Governance Definitions

Term	Controlled meaning
Data Owner	Named business role accountable for a data domain's classification, authorized use, access conditions, and lifecycle decisions.
Personal Data	Information relating to an identified or reasonably identifiable individual, used as a broad internal privacy concept without asserting any jurisdiction-specific statutory definition.
High-Sensitivity Personal Data (HSPD)	Synthetic Aurelius internal risk label for personal data requiring elevated protection because misuse or exposure could cause significant harm; not a statutory-category claim.
Security Incident	Security event or series of events that compromises, or credibly threatens to compromise, confidentiality, integrity, availability, authentication, or control of company/client resources.
Privacy Incident	Event involving unauthorized or inappropriate collection, access, use, disclosure, alteration, loss, retention, or deletion of Personal Data; may also be a Security Incident.
Major Incident	SEV-1 incident, or a designated SEV-2 incident, requiring coordinated cross-functional incident management.
Record	Information retained as evidence of a business decision, transaction, approval, obligation, incident, or controlled activity.

PRIV-DG-02-AB Data Flow Mapping Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Data Privacy & Data Governance Policy.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

Appendices - continued

PRIV-DG-02-AC Privacy-by-Design Review Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Data Privacy & Data Governance Policy.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

Appendices - continued

PRIV-DG-02-AD Data Retention/Deletion Evidence Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Data Privacy & Data Governance Policy.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

Appendices - continued

PRIV-DG-02-AE Privacy Incident Intake Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Data Privacy & Data Governance Policy.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

PRIV-DG-02-F01 Privacy Review Request

Field	Entry / controlled record
Requester / worker name	
Employee or worker ID	
Department / project	
Manager / sponsor	
Date / effective period	
Business purpose	
Requested action or decision	
Supporting evidence	
Approvals / concurrence	
Exception or risk notes	
Closure / outcome	
Record location	

Appendices - continued

PRIV-DG-02-F02 Data Owner Use/Sharing Decision Record

Field	Entry / controlled record
Requester / worker name	
Employee or worker ID	
Department / project	
Manager / sponsor	
Date / effective period	
Business purpose	
Requested action or decision	
Supporting evidence	
Approvals / concurrence	
Exception or risk notes	
Closure / outcome	
Record location	

Appendices - continued

PRIV-DG-02-F03 Individual Request Case Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Data Privacy & Data Governance Policy.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.